2026.09.26.3.4.S

Корпоративный стандарт

Информационная безопасность инфраструктуры

Настоящий Стандарт определяет единые требования, принципы и подходы к обеспечению информационной безопасности инфраструктуры Компании и является базовым документом, устанавливающим общие правила для всех частных политик, регламентов и процедур в области ИБ.

1. Структура

2. Общие положения 5
2.1. Назначение документа 5
2.2. Цели принятия Стандарта 5
2.3. Область применения 6
2.3.1. По составу подразделений и ролей: 6
2.3.2. По сетевой и технической инфраструктуре: 6
2.3.3. По информационным активам и категориям данных: 7
2.4. Порядок вступления в силу, контроль и пересмотр 7
2.5. Организационная структура и роли 8
2.5.1. RACI-матрица процессов ИБ 8
2.5.2. Детализация зон ответственности ролей 9
2.6. Термины, определения и сокращения 11
2.6.1. Термины и определения 11
2.6.2. Перечень сокращений и аббревиатур 12
3. Правила сетевого взаимодействия 13
3.1. Межсетевое экранирование на fw00_perimeter 13
3.1.1. Базовый принцип фильтрации трафика. 13
3.1.2. Централизация сетевого контроля. 13
3.1.3. Фильтрация входящего и исходящего трафика. 14
3.1.4. Защита сетевого периметра от подмены адресов. 14
3.2. Правила межсегментного взаимодействия 14
3.2.1. Изоляция демилитаризованной зоны (DMZ). 14
3.2.2. Защита контура обработки онлайн-платежей и ПДн. 14
3.2.3. Сегментация сетевого трафика (платежные и персональные данные). 14
3.2.4. Ограничение доступа к Инфраструктурному сегменту. 15
3.2.5. Регламентация административного трафика. 15
3.3. Требования к защите каналов удалённого доступа 15
3.3.1. Единственная точка входа для удалённой работы. 15
3.3.2. Криптографическая защита VPN-туннелей. 15
3.3.3. Двухфакторная аутентификация (MFA) для удалённых пользователей. 16
3.3.4. Сегментация удалённых клиентов. 16
3.3.5. Безопасность ключевой системы VPN. 16
3.4. Порядок внесения изменений в правила межсетевого экрана и их аудит 16
3.4.1. Управление изменениями правил фильтрации. 16
3.4.2. Периодический аудит правил фильтрации. 17
3.4.3. Регистрация событий межсетевого экранирования. 17
4. Требования к сервисам и приложениям 17
4.1. Защита веб-сервисов srv_web и srv_crm от уязвимостей OWASP Top 10 17
4.1.1. Защита от инъекционных атак. 17
4.1.3. Защита от межсайтового скриптинга (XSS) и CSRF. 18
4.1.4. Безопасность механизмов аутентификации. 18
4.2. Требования PCI DSS v4.0 и ГОСТ Р 57580.1-2017 к контуру обработки онлайн-платежей 18
4.2.1. Минимизация области действия стандартов (Scope Reduction). 18

4.2.2. Защита каналов передачи платёжных данных. 18
4.2.3. Контроль целостности платёжных веб-страниц. 19
4.3. Настройка безопасной конфигурации веб-серверов Nginx 19
4.3.1. Сокрытие системной информации (Nginx Hardening). 19
4.3.2. Обязательные заголовки безопасности (Security Headers). 19
4.4. Изоляция данных клиентов в SaaS-платформе 19
4.4.1. Межклиентская изоляция данных (Multitenant Security). 19
4.4.2. Изоляция и защита резервных копий клиентов. 20
5. Безопасная разработка ПО 20
5.1. Безопасный жизненный цикл разработки ПО (SDLC) 20
5.2. Интеграция проверок ИБ в сборочные пайплайны (CI/CD) 20
5.2.1. Автоматизация контроля ИБ в CI/CD. 20
5.2.2. Изоляция сред разработки, тестирования и продуктовой среды. 21
5.3. Автоматизированный анализ кода (SAST / DAST) 21
5.3.1. Статический анализ исходного кода (SAST). 21
5.3.2. Динамический анализ приложений (DAST). 21
5.4. Правила работы с репозиториями и запрет хранения секретов в Git 21
5.4.1. Категорический запрет секретов в коде (No Hardcoded Secrets). 21
5.4.2. Автоматический контроль коммитов на наличие секретов. 22
5.5. Безопасность сторонних библиотек и компонентов (SCA) 22
5.5.1. Анализ стороннего ПО и зависимостей (SCA). 22
5.5.2. Управление безопасностью цепочки поставок (Supply Chain Security). 22
6. Управление доступом и защита данных 22
6.1. Аутентификация и управление учетными записями в Active Directory odin.local 22
6.1.1. Централизованный учет пользователей. 22
6.1.2. Регламент блокировки учетных записей при увольнении. 23
6.2. Парольная политика и двухфакторная аутентификация (MFA) 23
6.2.1. Требования к сложности паролей. 23
6.2.2. Защита от подбора паролей. 23
6.2.3. Обязательная двухфакторная аутентификация (MFA). 23
6.3. Матрица доступов и принцип наименьших привилегий (Least Privilege) 24
6.3.1. Ограничение прав доступа. 24
6.3.2. Разделение обычных и административных учетных записей. 24
6.4. Защита персональных данных (ФЗ-152) 24
6.4.1. Законность сбора и согласия на обработку ПДн. 24
6.4.2. Локализация и порядок уничтожения ПДн. 24
6.5. Защита коммерческой тайны (ФЗ-98) 24
6.5.1. Режим охраны коммерческой тайны. 25
6.6. Порядок использования СКЗИ и средств электронной подписи 25
6.6.1. Учет и хранение ключевых носителей ЭП. 25
7. Мониторинг и логирование 25
7.1. Централизованный сбор и хранение логов (SIEM / Wazuh) 25
7.1.1. Обязательность регистрации событий безопасности. 25
7.1.2. Перечень обязательных для логирования событий. 25
7.1.3. Централизация и защищённость логов в SIEM/Wazuh. 26
7.1.4. Единый источник точного времени (NTP). 26

7.2. Управление конфигурациями и правила наименования хостов 26
7.2.1. Строгое соблюдение регламента именования хостов. 26
7.2.2. Ведение реестра активов в CMDB. 26
7.3. Управление уязвимостями и обновлениями (Patch Management) 27
7.3.1. Периодический поиск уязвимостей. 27
7.3.2. Сроки установки патчей безопасности. 27
7.3.3. Безопасная начальная настройка (Hardening). 27
7.4. Порядок реагирования на инциденты ИБ и уведомление Роскомнадзора 27
7.4.1. Фиксация и расследование инцидентов. 27
7.4.2. Обязательное уведомление Роскомнадзора в течение 24 часов. 27
8. Управление инцидентами ИБ 28
8.1. Классификация инцидентов и уровни критичности 28
8.2. Полный жизненный цикл реагирования на инциденты 29
9. Резервное копирование и восстановление (BCP / DRP) 30
9.1. Требования к резервному копированию данных 30
9.2. Целевые показатели восстановления (RTO и RPO) 30
9.3. Тестирование и контроль восстановления 31
10. Кадровая безопасность (HR Security) 31
10.1. Процедуры приема на работу 31
10.2. Обучение и повышение осведомленности (Security Awareness) 31
10.3. Процедуры изменения ролей и увольнения (Offboarding) 32
11. Управление активами (Asset Management) 32
11.1. Реестр активов и классификация информации 32
11.2. Списание и безопасное уничтожение (Decommissioning) 33
12. Физическая безопасность (Physical Security) 34
12.1. Контроль доступа в серверные помещения 34
12.2. Безопасность рабочих мест (Clean Desk Policy) 34
12.3. Защита мобильных устройств и ноутбуков 35
13. Безопасность третьих лиц (Third-Party Security) 35
13.1. Взаимодействие с подрядчиками и вендорами 35
13.2. Управление цепочкой поставок ПО 35
14. Ссылки на НПА и стандарты 36
14.1. Обоснование применимости нормативной базы для ИП«ОдинЗаВсех» 36
14.1.1. Обязательное применение по законодательству РФ 36
14.1.2. Обязательное применение по распоряжению руководства 37
14.1.3. Не применимые в компании 37
14.1.4. Желательное применение (Лучшие практики и методологии) 38
14.2. НПА и стандарты обязательные к применению по законодательству РФ 40
14.3. НПА и стандарты обязательные к применению по по распоряжению руководства 42
14.4. НПА и стандарты желательные к применению (лучшие практики и методологии) 43

2. Общие положения

2.1. Назначение документа

Настоящий Корпоративный стандарт информационной безопасности (далее - Стандарт) является главным внутренним нормативным документом в сфере информационной безопасности ИП «ОдинЗаВсех» (далее - Предприятие).
Стандарт устанавливает единые обязательные требования, правила и ограничения, направленные на обеспечение конфиденциальности, целостности и доступности информационных активов Предприятия, а также на устранение системных уязвимостей и рисков, выявленных по результатам независимого тестирования на проникновение (пентеста).

2.2. Цели принятия Стандарта

Главными целями внедрения настоящего Стандарта являются:
2.2.1. Устранение системных уязвимостей: Нейтрализация векторов атак и устранение недостатков в настройках сетевого оборудования, операционных систем, веб-сервисов и процедурах администрирования, подсвеченных в ходе пентеста.
2.2.2. Обеспечение регуляторного соответствия (Комплаенс): Выполнение обязательных требований законодательства РФ (ФЗ-152, ФЗ-149, ФЗ-98, ФЗ-63) и международных/отраслевых стандартов (OWASP Top 10, PCI DSS v4.0, ГОСТ Р 57580.1-2017, ГОСТ Р ИСО/МЭК 27001).
2.2.3. Защита ключевых бизнес-активов:
2.2.4. Защита исходного кода продуктов и проектной документации (коммерческая тайна);
2.2.5. Защита персональных данных (ПДн) клиентов и сотрудников Предприятия;
2.2.6. Защита финансовой отчётности и платёжных транзакций при эквайринге.
2.2.7. Обеспечение непрерывности SaaS-сервисов: Гарантирование высокой доступности и надежности облачной платформы управления задачами в соответствии с SLA, а также строгая изоляция данных различных заказчиков (multitenancy security).
2.2.8. Внедрение безопасной разработки (DevSecOps): Интеграция проверок безопасности на всех этапах создания и сопровождения таск-менеджер-приложений.

2.2.9. Распределение ответственности: Чёткое разграничение зон ответственности и обязанностей в сфере ИБ между Индивидуальным предпринимателем (Руководством), IT-отделом, Отделом ИБ, Отделом разработки, Менеджерами, Бухгалтерией и HR.

2.3. Область применения

Требования настоящего Стандарта распространяются на инфраструктуру, процессы и персонал Предприятия.

2.3.1. По составу подразделений и ролей:

Стандарт обязателен для исполнения всеми штатными сотрудниками, внештатными специалистами и внешними подрядчиками во всех подразделениях:

2.3.1.1. Руководство (Индивидуальный предприниматель) - в части утверждения политик и выделения ресурсов;

2.3.1.2. IT-отдел - в части администрирования ОС, сетей, доступов и инфраструктуры;

2.3.1.3. Отдел информационной безопасности - в части контроля, аудита и мониторинга;

2.3.1.4. Отдел разработки - в части кодирования, работы с Git, CI/CD пайплайнами и тестами;

2.3.1.5. Менеджеры - в части работы с профайлами клиентов, договорами и коммерческой тайной;

2.3.1.6. Финансово-бухгалтерский отдел - в части работы с платежами, банками и отчетностью;

2.3.1.7. Кадровая служба (HR) - в части обработки личных дел и кадрового учета.

2.3.2. По сетевой и технической инфраструктуре:

Требования Стандарта применяются ко всей вычислительной инфраструктуре Предприятия и логическим сегментам сети:

2.3.2.1. Периметровый межсетевой экран (fw00_perimeter);

2.3.2.2. Демилитаризованная зона (DMZ) - публичные веб-сервисы (srv_web, srv_crm, портал самообслуживания, OpenVPN);

2.3.2.3. Серверный сегмент - базы данных, файловые серверы, почта, база знаний;

2.3.2.4. Инфраструктурный сегмент - контроллер домена Active Directory (odin.local), DNS, NTP, LDAP;

2.3.2.5. Пользовательский сегмент - все АРМ сотрудников и администраторов.

Подробное описание сетевой топологии, подсетей, IP-адресации и конфигурации серверов приведено в документе "Паспорт компании ИП 'ОдинЗаВсех'".

2.3.3. По информационным активам и категориям данных:

Стандарт регламентирует защиту следующих категорий информации:

2.3.3.1. Персональные данные (ПДн): Данные клиентов в CRM и на сайте, личные дела сотрудников в HR;

2.3.3.2. Коммерческая тайна: Исходный код таск-менеджеров, архитектурная документация, профайлы клиентов;

2.3.3.3. Данные платежных карт и транзакций: Онлайн-эквайринг за подписки SaaS и заказные проекты (PCI DSS);

2.3.3.4. Учетные данные: Пароли, SSH/TLS-ключи, токены доступа, сертификаты ЭП.

2.4. Порядок вступления в силу, контроль и пересмотр

2.4.1. Вступление в силу: Стандарт вступает в силу с момента его утверждения Индивидуальным предпринимателем.

2.4.2. Обязательность ознакомления: Все действующие сотрудники, а также вновь принимаемые на работу лица обязаны пройти ознакомление со Стандартом под подпись.

2.4.3. Ответственность за контроль: Контроль выполнения требований Стандарта возлагается на Отдел информационной безопасности.

2.4.4. Плановый пересмотр: Документ подлежит плановому пересмотру и актуализации не реже 1 раза в год.

2.4.5. Внеплановый пересмотр:

Проводится немедленно при:

2.4.5.1. Существенных изменениях сетевой архитектуры или появлении новых сегментов;

2.4.5.2. Изменениях в законодательстве РФ в области ИБ и защиты ПДн;

2.4.5.3. Выявлении критических инцидентов ИБ или по результатам повторных пентестов.

2.5. Организационная структура и роли

Для четкого распределения обязанностей в сфере информационной безопасности и устранения пересечений в зонах ответственности в Стандарт ИБ внедряется RACI-матрица процессов ИБ.

2.5.1. RACI-матрица процессов ИБ

Расшифровка ролей RACI:

- **R (Responsible - Исполнитель):** Роль, которая непосредственно выполняет работу и реализует конкретную задачу.
- **A (Accountable - Ответственный / Утверждающий):** Единственная роль, которая несёт конечную ответственность за результат процесса и имеет право утверждения (только одна буква «A» на каждый процесс).
- **C (Consulted - Эксперт / Консультант):** Роль, предоставляющая экспертную информацию, необходимые данные или согласование до исполнения задачи.
- **I (Informed - Информируемый):** Роль, которая своевременно уведомляется о ходе процесса или его результатах.

№	Ключевой процесс ИБ	Руководство (ИП)	Отдел ИБ	IT-отдел	Отдел разработки	Менеджеры	Бухгалтерия	HR-служба
1.	Утверждение Политики ИБ и Корпоративного стандарта	**A**	**R**	**C**	**C**	**I**	**I**	**I**
2.	Управление рисками ИБ, проведение пентестов и аудитов	**A**	**R**	**C**	**C**	**I**	**I**	**I**
3.	Разграничение доступов, управление учетными записями (IAM / AD)	**I**	**A**	**R**	**C**	**C**	**C**	**C**
4.	Защита сетевого периметра (fw00_perimeter), сегментация и OpenVPN	**I**	**A**	**R**	**I**	**I**	**I**	**I**
5.	Безопасная разработка ПО (DevSecOps, OWASP Top 10, ревью кода)	**I**	**C**	**C**	**A / R**	**I**	**I**	**I**
6.	Защита персональных данных (ФЗ-152, взаимодействие с РКН)	**A**	**R**	**C**	**C**	**C**	**I**	**C**
7.	Безопасность эквайринга и платежных модулей (PCI DSS)	**I**	**A**	**C**	**R**	**I**	**C**	**I**
8.	Управление уязвимостями и патч-менеджмент (ОС, сервисы)	**I**	**A**	**R**	**R**	**I**	**I**	**I**
9.	Мониторинг ИБ, фиксация событий (SIEM/Wazuh)	**I**	**A / R**	**R**	**C**	**I**	**I**	**I**
10.	Инструктаж, обучение сотрудников и проверка на фишинг	**I**	**A / R**	**I**	**I**	**I**	**I**	**C**

№	Ключевой процесс ИБ	Руководство (ИП)	Отдел ИБ	IT-отдел	Отдел разработки	Менеджеры	Бухгалтерия	HR-служба
11.	Управление инцидентами ИБ (расследование, локализация)	**I**	**A / R**	**R**	**C**	**I**	**I**	**I**
12.	Резервное копирование и восстановление (BCP / DRP)	**A**	**C**	**R**	**I**	**I**	**I**	**I**
13.	Кадровая безопасность (NDA, онбординг, увольнение)	**A**	**C**	**R**	**I**	**I**	**I**	**R**
14.	Управление активами (CMDB, классификация, уничтожение)	**A**	**C**	**R**	**I**	**I**	**I**	**I**
15.	Физическая безопасность (СКУД, Clean Desk, серверная)	**A**	**C**	**R**	**I**	**R**	**R**	**C**
16.	Безопасность третьих лиц (подрядчики, вендоры)	**A**	**C**	**R**	**I**	**C**	**C**	**I**

2.5.2. Детализация зон ответственности ролей

2.5.2.1. Руководство (Индивидуальный предприниматель)

2.5.2.1.1. Несет юридическую ответственность перед государством (ФЗ-152) и клиентами (SLA).

2.5.2.1.2. Утверждает бюджеты на средства резервного копирования и физической защиты.

2.5.2.1.3. Подписывает договоры с подрядчиками, принимая на себя риски взаимодействия с третьими лицами.

2.5.2.1.4. Утверждает акты списания критичных активов.

2.5.2.2. Отдел информационной безопасности

2.5.2.2.1. Главный орган контроля.

2.5.2.2.2. Расследует инциденты ИБ (Раздел 8).

2.5.2.2.3. Проводит проверки соблюдения политики «чистого стола» и контролирует физический доступ в серверную (Раздел 12).

2.5.2.2.4. Проводит аудит резервных копий и организует их тестовое восстановление (Раздел 9).

2.5.2.2.5. Проверяет подрядчиков на соответствие требованиям ИБ перед выдачей доступа (Раздел 13).

2.5.2.2.6. Ведет классификацию активов (Раздел 11).

2.5.2.3. IT-отдел

2.5.2.3.1. Выполняет техническую настройку систем резервного копирования и восстанавливает данные по запросу ИБ (Раздел 9).

2.5.2.3.2. Обеспечивает физическую безопасность серверной: управляет СКУД, следит за датчиками температуры и пожаротушения, ведет журнал посещений (Раздел 12).

2.5.2.3.3. Заводит карточки активов в CMDB, проводит безопасное затирание (Overwriting) дисков при списании оборудования (Раздел 11).

2.5.2.3.4. Настраивает бастион-хосты и временные доступы для подрядчиков (Раздел 13).

2.5.2.3.5. Блокирует учетные записи при увольнении (совместно с HR).

2.5.2.4. Отдел разработки

2.5.2.4.1. Отвечает за качество и безопасность кода.

2.5.2.4.2. Обеспечивает сохранность интеллектуальной собственности (исходного кода), соблюдая правила работы с репозиториями (Раздел 5).

2.5.2.4.3. Участвует в расследовании инцидентов, если они связаны с компрометацией кода или уязвимостями ПО (Раздел 8).

2.5.2.4.4. Несет ответственность за сохранность выданного оборудования (ноутбуков) и шифрование дисков (Раздел 12.3).

2.5.2.5. Менеджеры

2.5.2.5.1. Инициаторы заявок на доступ для новых клиентов.

2.5.2.5.2. Обязаны соблюдать режим конфиденциальности при работе с профайлами клиентов.

2.5.2.5.3. Соблюдают политику «чистого стола» и правила физической безопасности.

2.5.2.5.4. Несут ответственность за сохранность вверенных активов (ноутбуков, смартфонов).

2.5.2.6. Финансово-бухгалтерский отдел

2.5.2.6.1. Используют сертифицированные токены (СКЗИ) для ЭП.

2.5.2.6.2. Соблюдают правила обработки конфиденциальных платёжных документов и политику «чистого стола».

2.5.2.6.3. При взаимодействии с внешними аудиторами или банковскими подрядчиками - согласовывают их доступ с Отделом ИБ (Раздел 13).

2.5.2.7. Кадровая служба (HR)

2.5.2.7.1. Обеспечивает сбор подписей под NDA, Согласиями на обработку ПДн и ознакомление с настоящим Стандартом при приеме на работу (Раздел 10).
2.5.2.7.2. Критически важно: своевременно (в день издания приказа) уведомляет IT и ИБ-отделы об увольнениях или переводах сотрудников для оперативной блокировки доступов (Раздел 10.3).
2.5.2.7.3. Организует ежегодное обучение сотрудников (Security Awareness).

2.6. Термины, определения и сокращения

2.6.1. Термины и определения

В настоящем Стандарте применяются следующие термины и определения:

№	Термин	Определение
1.	**Информационная безопасность (ИБ)**	Состояние защищенности информационных активов Предприятия от внутренних и внешних угроз, обеспечивающее конфиденциальность, целостность и доступность информации.
2.	**Информационный актив**	Любая информация, база данных, исходный код, сервис или оборудование, имеющее ценность для Предприятия (включая srv_web, srv_crm, базы данных и исходный код таск-менеджера).
3.	**Персональные данные (ПДн)**	Любая информация, относящаяся к прямо или косвенно определенному или определяемому физическому лицу (субъекту ПДн), обрабатываемая в ИСПДн Предприятия (согласно ФЗ-152).
4.	**Демилитаризованная зона (DMZ)**	Сетевой сегмент (10.10.1.0/27), изолированный межсетевым экраном от внутренних сетей, предназначенный для размещения публичных сервисов (srv_web, srv_crm, srv_wg).
5.	**Межсетевой экран (Firewall)**	Программно-аппаратный комплекс fw00_perimeter, обеспечивающий фильтрацию сетевого трафика и контроль доступа между сегментами сети и внешней средой на основе установленных правил.
6.	**Микросегментация**	Метод сетевой безопасности, заключающийся в логическом разделении сети на изолированные сегменты (DMZ, Servers, Users, Infra) и строгом контроле трафика между ними через fw00_perimeter.
7.	**Уязвимость**	Недостаток или слабое место в программном обеспечении, конфигурации или процессе, который может быть использован злоумышленником для нарушения ИБ (оценивается по шкале CVSS).
8.	**Пентест (Penetration Test)**	Авторизованная имитация кибератаки на инфраструктуру и веб-сервисы Предприятия с целью оценки уровня защищенности и выявления уязвимостей.
9.	**Инцидент ИБ**	Любое событие или действие, приводящее или способное привести к компрометации активов, утечке ПДн или нарушению доступности сервисов (SLA).
10.	**Секрет (Secret)**	Конфиденциальные данные (пароли, API-ключи, токены, SSH/TLS-сертификаты,

№	Термин	Определение
		приватные ключи), используемые для доступа к системам и требующие защищенного хранения вне исходного кода.
11.	**Компенсирующая мера**	Организационная или техническая мера, применяемая для снижения риска, если выполнение базового требования ИБ невозможно по техническим или бизнес-причинам.
12.	**Hardening (Безопасная настройка)**	Процесс снижения поверхности атаки путем отключения неиспользуемых сервисов, портов и приведения конфигурации ОС или ПО в соответствие с профилями безопасности (CIS Benchmarks).
13.	**SLA (Service Level Agreement)**	Соглашение об уровне обслуживания, определяющее допустимое время простоя SaaS-платформы и время реакции на инциденты для клиентов.
14.	**Мультитенантность (Multitenancy)**	Архитектурный принцип SaaS-платформы, при котором данные различных клиентов (арендаторов) логически изолированы друг от друга на уровне БД и приложений.

2.6.2. Перечень сокращений и аббревиатур

Сокращение	Расшифровка
АРМ	Автоматизированное рабочее место (рабочая станция пользователя или администратора).
БД	База данных.
БДУ ФСТЭК	Банк данных угроз безопасности информации ФСТЭК России.
ИБ	Информационная безопасность.
ИП	Индивидуальный предприниматель (в контексте документа - высший орган управления).
ИСПДн	Информационная система персональных данных.
НПА	Нормативные правовые акты.
ОС	Операционная система (Linux Ubuntu, Windows Server, Windows 11).
ПДн	Персональные данные.
СЗИ / СКЗИ	Средства защиты информации / Средства криптографической защиты информации.
СУИБ	Система управления информационной безопасностью.
BCP	План непрерывности бизнеса (Бизнес-процессы, люди, офисы, репутация, логистика).
DRP	План аварийного восстановления (Данные, серверы, сети, софт, ИТ-периметр).
CI/CD	Continuous Integration / Continuous Deployment (непрерывная интеграция и развертывание кода).
CMDB	Configuration Management Database (база данных управления конфигурациями).
CSP	Content Security Policy (политика безопасности контента на веб-серверах).
CVSS	Common Vulnerability Scoring System (система оценки критичности уязвимостей).
DAST	Dynamic Application Security Testing (динамический анализ безопасности приложений).
DMZ	Demilitarized Zone (демилитаризованная зона).

Сокращение	Расшифровка
MFA	Multi-Factor Authentication (многофакторная аутентификация).
OWASP	Open Web Application Security Project (открытый проект по безопасности веб-приложений).
RACI	Responsibility, Accountability, Consulted, Informed (матрица распределения ответственности).
SAST	Static Application Security Testing (статический анализ безопасности кода).
SCA	Software Composition Analysis (анализ состава и зависимостей стороннего ПО).
SDLC	Software Development Life Cycle (жизненный цикл разработки ПО).
SIEM	Security Information and Event Management (система управления событиями и информацией безопасности, в данном документе - Wazuh).
SSDF	Secure Software Development Framework (фреймворк безопасной разработки NIST).
TOTP	Time-based One-Time Password (алгоритм генерации одноразовых паролей).
VPN	Virtual Private Network (виртуальная частная сеть, в данном документе - OpenVPN на базе srv_wg).

3.Правила сетевого взаимодействия

3.1. Межсетевое экранирование на fw00_perimeter

3.1.1. Базовый принцип фильтрации трафика.

На межсетевом экране fw00_perimeter устанавливается политика запрета по умолчанию (Default Deny). Любой сетевой трафик, не разрешённый явным образом в правилах фильтрации, автоматически блокируется и отбрасывается. [8.3.2 NIST SP 800-41 Rev. 1], [8.3.3 NIST SP 800-207], [8.4.3 CIS Controls v8], [8.2.1 ФЗ-149]

3.1.2. Централизация сетевого контроля.

Любое взаимодействие между сетевыми сегментами DMZ (10.10.1.0/27), Серверным (10.10.2.0/26), Пользовательским (10.10.4.0/25), Инфраструктурным (10.10.5.0/28), а также с внешней сетью Интернет, осуществляется исключительно через межсетевой экран fw00_perimeter. Организация прямых сетевых соединений в обход fw00_perimeter запрещена. [8.3.2 NIST SP 800-41 Rev. 1], [8.2.1 ФЗ-149], [8.2.9 Приказ ФСТЭК № 21]

3.1.3. Фильтрация входящего и исходящего трафика.

На внешнем интерфейсе fw00_perimeter должна быть настроена двусторонняя фильтрация трафика. Исходящий трафик из внутренних сегментов в сеть Интернет ограничивается только явно необходимыми протоколами и портами (HTTPS/443 для обновлений, NTP/123 для синхронизации времени). Неконтролируемый исходящий трафик запрещён. [8.3.2 NIST SP 800-41 Rev. 1], [8.3.4 PCI DSS v4.0], [8.4.15 ГОСТ Р ИСО/МЭК 27002-2021]

3.1.4. Защита сетевого периметра от подмены адресов.

На периметровом оборудовании fw00_perimeter должны быть включены механизмы защиты от IP-спуфинга (фильтрация пакетов с некорректными или частными IP-адресами на внешнем интерфейсе) и блокировка невалидных пакетов. [8.3.2 NIST SP 800-41 Rev. 1], [8.4.4 CIS Benchmarks]

3.2. Правила межсегментного взаимодействия

3.2.1. Изоляция демилитаризованной зоны (DMZ).

Узлам, расположенным в сегменте DMZ (10.10.1.0/27) - веб-сервисам srv_web, srv_crm и порталу самообслуживания - запрещено инициализировать сетевые соединения во внутренние сегменты (Серверный, Инфраструктурный, Пользовательский). Исключение составляют только строго определённые соединения, инициируемые к конкретным портам сервисов (например, доступ srv_crm к СУБД CRM 10.10.2.0/26 только по порту СУБД). [8.3.2 NIST SP 800-41 Rev. 1], [8.3.4 PCI DSS v4.0], [8.3.5 ГОСТ Р 57580.1-2017], [8.2.9 Приказ ФСТЭК № 21]

3.2.2. Защита контура обработки онлайн-платежей и ПДн.

Контур обработки платёжных данных (CDE - Cardholder Data Environment) должен быть строго изолирован от остальной инфраструктуры. Все системы, обрабатывающие платёжные данные (srv_web, srv_crm и БД CRM), должны быть выделены в отдельный логический сегмент с максимально строгими правилами фильтрации (Default Deny) на fw00_perimeter согласно требованиям PCI DSS v4.0.

3.2.3. Сегментация сетевого трафика (платежные и персональные данные).

Сетевой трафик, связанный с обработкой платёжных карт и персональных данных клиентов на сервисах srv_web и srv_crm, должен быть логически сегментирован. Прямой доступ из

Пользовательского сегмента (10.10.4.0/25) к Базе данных CRM (10.10.2.0/26) запрещён; доступ разрешается только к веб-интерфейсам приложений по защищённому протоколу HTTPS. [8.3.4 PCI DSS v4.0], [8.3.5 ГОСТ Р 57580.1-2017], [8.2.2 ФЗ-152], [8.2.9 Приказ ФСТЭК № 21]

3.2.4. Ограничение доступа к Инфраструктурному сегменту.

Рабочим станциям Пользовательского сегмента (10.10.4.0/25) запрещён прямой доступ к Инфраструктурным сервисам (10.10.5.0/28), за исключением портов, необходимых для функционирования службы Active Directory odin.local (DNS/53, NTP/123, Kerberos/88, LDAP/389/636). Прямой административный доступ (RDP, SSH, WinRM) с обычных АРМ на Контроллер домена и серверы инфраструктуры запрещён. [8.3.2 NIST SP 800-41 Rev. 1], [8.3.3 NIST SP 800-207], [8.2.9 Приказ ФСТЭК № 21]

3.2.5. Регламентация административного трафика.

Доступ к интерфейсам управления серверным и сетевым оборудованием (SSH, RDP, HTTPS-консоли) во всех сегментах разрешается только с выделенных административных АРМ или через специализированный бастионный хост с обязательным шифрованием и протоколированием сессий. [8.3.2 NIST SP 800-41 Rev. 1], [8.4.3 CIS Controls v8], [8.4.15 ГОСТ Р ИСО/МЭК 27002-2021]

3.3. Требования к защите каналов удалённого доступа

3.3.1. Единственная точка входа для удалённой работы.

Подключение удалённых сотрудников к корпоративной сети осуществляется исключительно через сервер OpenVPN, размещённый в DMZ-сегменте (10.10.1.0/27). Прямой проброс портов из сети Интернет к рабочим станциям (10.10.4.0/25) или внутренним серверам (10.10.2.0/26) категорически запрещён. [8.3.2 NIST SP 800-41 Rev. 1], [8.2.11 Приказ ФСБ № 378], [8.2.1 ФЗ-149]

3.3.2. Криптографическая защита VPN-туннелей.

Защита передаваемых удалёнными сотрудниками данных (включая ПДн и коммерческую тайну) должна обеспечиваться использованием стойких криптографических алгоритмов шифрования (TLS 1.2/1.3, AES-256 или ГОСТ-алгоритмов при передаче ПДн в соответствии

с классом СКЗИ). [8.2.11 Приказ ФСБ № 378], [8.2.13 № 149/7/2/6-432], [8.3.4 PCI DSS v4.0], [8.2.4 ФЗ-98]

3.3.3. Двухфакторная аутентификация (MFA) для удалённых пользователей.

Все сессии удалённого доступа через OpenVPN в обязательном порядке должны требовать прохождения двухфакторной аутентификации (пароль учетной записи в Active Directory + одноразовый TOTP-код или сертификат). [8.3.4 PCI DSS v4.0], [8.3.3 NIST SP 800-207], [8.2.9 Приказ ФСТЭК № 21]

3.3.4. Сегментация удалённых клиентов.

Удалённым пользователям, подключенным через OpenVPN, на fw00_perimeter выделяется изолированная виртуальная подсеть. Доступ из этой подсети к внутренним ресурсам Компании разграничивается правилами фильтрации на основе ролевой модели (менеджеры - только к CRM и файловому серверу; разработчики - только к Dev-сервисам и Git). [8.3.2 NIST SP 800-41 Rev. 1], [8.3.3 NIST SP 800-207], [8.2.9 Приказ ФСТЭК № 21]

3.3.5. Безопасность ключевой системы VPN.

Выпуск, учет, отзыв и хранение цифровых сертификатов и ключей доступа к OpenVPN должны осуществляться в соответствии с регламентом учета ключевых документов. [8.2.12 Приказ ФАПСИ № 152], [8.2.5 ФЗ-63]

3.4. Порядок внесения изменений в правила межсетевого экрана и их аудит

3.4.1. Управление изменениями правил фильтрации.

Любое изменение правил фильтрации на fw00_perimeter (добавление, изменение, удаление) осуществляется только после письменной заявки, согласованной с Отделом ИБ. Правило должно содержать бизнес-обоснование, IP-адреса источника и назначения, порты, протокол и срок действия (для временных правил). [8.3.2 NIST SP 800-41 Rev. 1], [8.3.6 ГОСТ Р ИСО/МЭК 27001-2021], [8.4.15 ГОСТ Р ИСО/МЭК 27002-2021]

3.4.2. Периодический аудит правил фильтрации.

Отдел ИБ совместно с IT-отделом обязан проводить ревизию активных правил на межсетевом экране fw00_perimeter не реже одного раза в квартал. Временные, неактуальные, дублирующие или избыточно разрешающие правила подлежат немедленному удалению. [8.3.2 NIST SP 800-41 Rev. 1], [8.3.4 PCI DSS v4.0], [8.4.3 CIS Controls v8]

3.4.3. Регистрация событий межсетевого экранирования.

Межсетевой экран fw00_perimeter должен обеспечивать протоколирование всех заблокированных попыток установления соединений (Deny/Drop logs), а также всех событий изменения конфигурации. Лог-файлы должны передаваться в режиме реального времени на централизованный сервер сбора логов (SIEM / Wazuh). [8.3.2 NIST SP 800-41 Rev. 1], [8.3.4 PCI DSS v4.0], [8.2.9 Приказ ФСТЭК № 21], [8.2.3 ФЗ-266]

4. Требования к сервисам и приложениям

4.1. Защита веб-сервисов srv_web и srv_crm от уязвимостей OWASP Top 10

4.1.1. Защита от инъекционных атак.

На веб-сервисах srv_web, srv_crm и портале самообслуживания обработка любых пользовательских данных должна выполняться с использованием подготовленных выражений (prepared statements), параметризованных запросов или ORM. Все входящие данные подлежат обязательной валидации и фильтрации на стороне сервера [8.3.1 OWASP Top 10 (2021) / API Top 10 (2023)], [8.4.4 CIS Benchmarks]

4.1.2. Контроль доступа на уровне приложений и API.

В веб-приложениях и REST API должен быть реализован строгий контроль полномочий для каждого запроса на стороне сервера. Нельзя полагаться на скрытие элементов в пользовательском интерфейсе. Должна быть исключена возможность несанкционированного доступа к чужим объектам путем изменения их идентификаторов в

запросе (защита от IDOR/BOLA) [8.3.1 OWASP Top 10 (2021) / API Top 10 (2023)], [8.3.6 ГОСТ Р ИСО/МЭК 27001-2021]

4.1.3. Защита от межсайтового скриптинга (XSS) и CSRF.

Веб-приложения должны выполнять экранирование и кодирование любого динамического вывода. Для всех аутентификационных cookie должны устанавливаться флаги HttpOnly, Secure и SameSite=Strict. Для защищенных форм должна быть настроена проверка CSRF-токенов и заголовки Content-Security-Policy (CSP) [8.3.1 OWASP Top 10 (2021) / API Top 10 (2023)]

4.1.4. Безопасность механизмов аутентификации.

В веб-сервисах должна быть настроена защита от перебора паролей (ограничение частоты запросов rate limiting), зашифрованное хранение паролей с использованием стойких адаптивных функций хэширования (Argon2, bcrypt), а также ограничение времени неактивной пользовательской сессии [8.3.1 OWASP Top 10 (2021) / API Top 10 (2023)], [8.2.9 Приказ ФСТЭК № 21]

4.2. Требования PCI DSS v4.0 и ГОСТ Р 57580.1-2017 к контуру обработки онлайн-платежей

4.2.1. Минимизация области действия стандартов (Scope Reduction).

Приём онлайн-платежей за подписки и проекты на srv_web и srv_crm должен осуществляться с использованием перенаправления (Redirect) или встраиваемых защищенных фреймов (Iframe) сертифицированного платёжного шлюза эквайера. Хранение, обработка или передача полных номеров платёжных карт (PAN) и CVV/CVC-кодов на собственных серверах Компании категорически запрещены [8.3.4 PCI DSS v4.0], [8.3.5 ГОСТ Р 57580.1-2017]

4.2.2. Защита каналов передачи платёжных данных.

Любое взаимодействие между веб-серверами Компании, клиентскими браузерами и платёжным шлюзом должно выполняться исключительно по защищённому протоколу TLS версии 1.2 или TLS 1.3 с использованием стойких наборов шифров. Передача данных по

незащищённым протоколам HTTP запрещена [8.3.4 PCI DSS v4.0], [8.3.5 ГОСТ Р 57580.1-2017], [8.2.11 Приказ ФСБ № 378]

4.2.3. Контроль целостности платёжных веб-страниц.

На сервисах srv_web и srv_crm должны быть внедрены механизмы мониторинга целостности клиентских скриптов (Subresource Integrity, SRI) и заголовков безопасности для предотвращения внедрения стороннего вредоносного кода на страницы оплаты (защита от Magecart и Web Skimming) [8.3.4 PCI DSS v4.0]

4.3. Настройка безопасной конфигурации веб-серверов Nginx

4.3.1. Сокрытие системной информации (Nginx Hardening).

На веб-серверах Nginx в DMZ-сегменте должно быть отключено отображение версии веб-сервера в заголовках ответов и на страницах ошибок (параметр server_tokens off). Должны быть отключены все неиспользуемые HTTP-методы и модули [8.4.4 CIS Benchmarks], [8.3.1 OWASP Top 10 (2021) / API Top 10 (2023)]

4.3.2. Обязательные заголовки безопасности (Security Headers).

Конфигурация Nginx должна содержать принудительную установку заголовков: Strict-Transport-Security (HSTS), X-Frame-Options (DENY или SAMEORIGIN), X-Content-Type-Options (nosniff), Referrer-Policy и Content-Security-Policy [8.4.4 CIS Benchmarks], [8.3.1 OWASP Top 10 (2021) / API Top 10 (2023)]

4.4. Изоляция данных клиентов в SaaS-платформе

4.4.1. Межклиентская изоляция данных (Multitenant Security).

В архитектуре SaaS-платформы должно быть реализовано гарантированное логическое разграничение данных различных организаций на уровне базы данных и приложения (Tenant ID Isolation). Выполнение бизнес-логики или SQL-запросов без явного фильтра по идентификатору арендатора (Tenant) запрещено [8.3.1 OWASP Top 10 (2021) / API Top 10 (2023)], [8.3.6 ГОСТ Р ИСО/МЭК 27001-2021], [8.2.2 ФЗ-152]

4.4.2. Изоляция и защита резервных копий клиентов.

Резервные копии баз данных SaaS-платформы должны шифроваться и храниться отдельно от основной рабочей среды. Процедуры восстановления из бэкапов не должны приводить к смешиванию данных разных заказчиков [8.3.6 ГОСТ Р ИСО/МЭК 27001-2021], [8.4.3 CIS Controls v8]

5. Безопасная разработка ПО

5.1. Безопасный жизненный цикл разработки ПО (SDLC)

5.1.1. Внедрение принципов Security by Design.

Требования информационной безопасности должны формироваться и учитываться на самых ранних этапах проектирования новых функций таск-менеджера и заказных решений [8.4.1 ГОСТ Р 56939-2024 / ГОСТ Р 58412-2019], [8.4.2 NIST SP 800-218 (SSDF) / OWASP SAMM v2.0]

5.1.2. Обязательное рецензирование кода (Peer Code Review).

Запрещается прямое слияние (merge) изменений в основные ветки репозиториев (main/master) без прохождения проверки кода минимум одним квалифицированным разработчиком и автоматическими сканерами [8.4.1 ГОСТ Р 56939-2024 / ГОСТ Р 58412-2019], [8.4.2 NIST SP 800-218 (SSDF) / OWASP SAMM v2.0]

5.2. Интеграция проверок ИБ в сборочные пайплайны (CI/CD)

5.2.1. Автоматизация контроля ИБ в CI/CD.

В сборочные пайплайны должны быть интегрированы автоматические инструменты проверки кода. При обнаружении уязвимостей критического (Critical) или высокого (High) уровня риск-баллов сборка проекта должна автоматически прерываться (Fail the Build) [8.4.1

ГОСТ Р 56939-2024 / ГОСТ Р 58412-2019], [8.4.2 NIST SP 800-218 (SSDF) / OWASP SAMM v2.0]

5.2.2. Изоляция сред разработки, тестирования и продуктовой среды.

Среды разработки (Dev), тестирования (Test) и продакшена (Prod) должны быть полностью разделены на сетевом и логическом уровнях. Использование реальных персональных данных клиентов и платёжной информации в средах разработки и тестирования строго запрещено [8.4.1 ГОСТ Р 56939-2024 / ГОСТ Р 58412-2019], [8.2.2 ФЗ-152], [8.3.4 PCI DSS v4.0]

5.3. Автоматизированный анализ кода (SAST / DAST)

5.3.1. Статический анализ исходного кода (SAST).

Весь разрабатываемый исходный код должен проходить регулярное автоматическое сканирование инструментами SAST для выявления потенциальных программных ошибок, инъекций и уязвимостей до момента попадания в релиз [8.4.1 ГОСТ Р 56939-2024 / ГОСТ Р 58412-2019], [8.4.6 MITRE CWE / CVE / FIRST CVSS]

5.3.2. Динамический анализ приложений (DAST).

Тестовые контуры приложений перед выпуском релизов в промышленную эксплуатацию подлежат динамическому сканированию инструментами DAST для поиска уязвимостей времени выполнения [8.4.1 ГОСТ Р 56939-2024 / ГОСТ Р 58412-2019], [8.3.1 OWASP Top 10 (2021) / API Top 10 (2023)]

5.4. Правила работы с репозиториями и запрет хранения секретов в Git

5.4.1. Категорический запрет секретов в коде (No Hardcoded Secrets).

Запрещается хранение паролей, API-ключей, токенов, сертификатов и приватных ключей шифрования в исходном коде и репозиториях Git. Передача секретов в приложения должна выполняться исключительно через переменные окружения или специализированные

менеджеры секретов. [8.4.1 ГОСТ Р 56939-2024 / ГОСТ Р 58412-2019], [8.3.1 OWASP Top 10 (2021) / API Top 10 (2023)]

5.4.2. Автоматический контроль коммитов на наличие секретов.

В репозиториях кода должны быть настроены предкоммитные хуки (pre-commit hooks) и сканеры Git для автоматической блокировки попыток отправки коммитов, содержащих секретные данные или ключи. [8.4.1 ГОСТ Р 56939-2024 / ГОСТ Р 58412-2019], [8.4.3 CIS Controls v8]

5.5. Безопасность сторонних библиотек и компонентов (SCA)

5.5.1. Анализ стороннего ПО и зависимостей (SCA).

Все сторонние библиотеки, Open-Source фреймворки и зависимости должны проходить непрерывный автоматический аудит с использованием инструментов SCA и сверкой с базами БДУ ФСТЭК и CVE/NVD. [8.4.1 ГОСТ Р 56939-2024 / ГОСТ Р 58412-2019], [8.4.10 БДУ ФСТЭК], [8.3.1 OWASP Top 10 (2021) / API Top 10 (2023)]

5.5.2. Управление безопасностью цепочки поставок (Supply Chain Security).

Запрещается использование заброшенных, неаудированных или неиспользуемых сторонних библиотек. Версии всех зависимостей должны быть строго зафиксированы в конфигурационных файлах сборки (lock-файлы). [8.4.1 ГОСТ Р 56939-2024 / ГОСТ Р 58412-2019], [8.4.2 NIST SP 800-218 (SSDF) / OWASP SAMM v2.0]

6. Управление доступом и защита данных

6.1. Аутентификация и управление учетными записями в Active Directory odin.local

6.1.1. Централизованный учет пользователей.

Управление всеми учетными записями сотрудников Компании осуществляется централизованно в домене Active Directory odin.local. Использование локальных учетных записей на рабочих станциях и серверах минимизируется и допускается только для сервисных служб [8.4.3 CIS Controls v8], [8.2.9 Приказ ФСТЭК № 21]

6.1.2. Регламент блокировки учетных записей при увольнении.

При изменении должностных обязанностей или увольнении сотрудника его учетная запись в Active Directory, OpenVPN, репозиториях Git, CRM и корпоративной почте должна блокироваться немедленно (не позднее 1 часа с момента выпуска приказа) [8.2.9 Приказ ФСТЭК № 21], [8.3.6 ГОСТ Р ИСО/МЭК 27001-2021], [8.3.4 PCI DSS v4.0]

6.2. Парольная политика и двухфакторная аутентификация (MFA)

6.2.1. Требования к сложности паролей.

Пароли пользователей в домене odin.local должны иметь длину не менее 12 символов, содержать заглавные и строчные латинские буквы, цифры и спецсимволы. Срок действия пароля ограничен 90 днями. Повторное использование последних 5 паролей запрещено [8.2.9 Приказ ФСТЭК № 21], [8.3.4 PCI DSS v4.0], [8.4.4 CIS Benchmarks]

6.2.2. Защита от подбора паролей.

В доменной политике должна быть настроена автоматическая блокировка учетной записи на 15 минут при совершении 5 подряд неверных попыток ввода пароля [8.2.9 Приказ ФСТЭК № 21], [8.3.4 PCI DSS v4.0]

6.2.3. Обязательная двухфакторная аутентификация (MFA).

Все сессии удалённого доступа через OpenVPN в обязательном порядке должны требовать прохождения двухфакторной аутентификации (пароль учетной записи в Active Directory + одноразовый TOTP-код или сертификат). Применение MFA также является обязательным для административного доступа к оборудованием и сервисам [8.3.4 PCI DSS v4.0], [8.3.3 NIST SP 800-207], [8.2.9 Приказ ФСТЭК № 21]

6.3. Матрица доступов и принцип наименьших привилегий (Least Privilege)

6.3.1. Ограничение прав доступа.

Доступ сотрудников к файловым серверам, базам данных и исходным кодам предоставляется исключительно на основе принципа наименьших привилегий и в соответствии с утвержденной Матрицей доступов. Предоставление избыточных прав запрещено [8.2.9 Приказ ФСТЭК № 21], [8.3.6 ГОСТ Р ИСО/МЭК 27001-2021], [8.3.4 PCI DSS v4.0]

6.3.2. Разделение обычных и административных учетных записей.

Для выполнения повседневных рабочих задач и для административных действий с инфраструктурой должны использоваться разные учетные записи. Использование учетной записи с правами Администратора домена для повседневной работы запрещено [8.4.3 CIS Controls v8], [8.4.4 CIS Benchmarks]

6.4. Защита персональных данных (ФЗ-152)

6.4.1. Законность сбора и согласия на обработку ПДн.

Обработка персональных данных клиентов и сотрудников выполняется строго при наличии надлежащим образом оформленных согласий или в рамках договоров. На веб-ресурсах srv_web и srv_crm должны быть опубликованы действующая Политика обработки ПДн и формы сбора согласий [8.2.2 ФЗ-152], [8.2.14 Приказы РКН № 14, 178, 996]

6.4.2. Локализация и порядок уничтожения ПДн.

Базы данных с персональными данными граждан РФ должны физически располагаться на территории РФ. По достижении целей обработки или при отзыве согласия персональные данные подлежат гарантированному уничтожению с составлением соответствующего Акта [8.2.2 ФЗ-152], [8.2.14 Приказы РКН № 14, 178, 996]

6.5. Защита коммерческой тайны (ФЗ-98)

6.5.1. Режим охраны коммерческой тайны.

Исходный код таск-менеджеров, проектная документация и файлы клиентов относятся к коммерческой тайне Компании. Доступ к Файловому серверу с исходным кодом предоставляется только авторизованным сотрудникам Отдела разработки. Все носители и документы подлежат маркировке [8.2.4 ФЗ-98], [8.2.6 Указ № 188]

6.6. Порядок использования СКЗИ и средств электронной подписи

6.6.1. Учет и хранение ключевых носителей ЭП.

Все аппаратные токены с сертификатами электронной подписи (Рутокен, JaCarta) и лицензии СКЗИ подлежат обязательному поэкземплярному учету в Журнале учета СКЗИ. Оставление ключевых носителей в АРМ без присмотра запрещено. Носители должны храниться в сейфах у ответственных лиц [8.2.5 ФЗ-63], [8.2.12 Приказ ФАПСИ № 152]

7. Мониторинг и логирование

7.1. Централизованный сбор и хранение логов (SIEM / Wazuh)

7.1.1. Обязательность регистрации событий безопасности.

На всех серверах Linux Ubuntu, Windows Server, АРМ Windows 11, межсетевом экране fw00_perimeter и веб-сервисах Nginx должно быть включено непрерывное ведение журналов аудита ИБ [8.2.9 Приказ ФСТЭК № 21], [8.3.4 PCI DSS v4.0], [8.4.3 CIS Controls v8]

7.1.2. Перечень обязательных для логирования событий.

Журналированию подлежат: все успешные и неудачные попытки входа в системы, изменения прав доступа и состава групп, создание и удаление учетных записей, сбросы логов, запросы к платежным модулям и БД CRM, изменения правил межсетевого экрана [8.2.9 Приказ ФСТЭК № 21], [8.3.4 PCI DSS v4.0], [8.4.15 ГОСТ Р ИСО/МЭК 27002-2021]

7.1.3. Централизация и защищённость логов в SIEM/Wazuh.

Все журналы событий должны передаваться в режиме реального времени на централизованный сервер SIEM/Wazuh. Доступ к серверу SIEM разрешен только сотрудникам Отдела ИБ. Редактирование и удаление лог-файлов запрещено. Срок хранения логов - не менее 1 года [8.3.4 PCI DSS v4.0], [8.2.9 Приказ ФСТЭК № 21], [8.4.3 CIS Controls v8]

7.1.4. Единый источник точного времени (NTP).

Все сетевые устройства, серверы и АРМ должны синхронизировать системное время с единым внутренним NTP-сервером в Инфраструктурном сегменте (10.10.5.0/28) [8.3.4 PCI DSS v4.0], [8.4.4 CIS Benchmarks]

7.2. Управление конфигурациями и правила наименования хостов

7.2.1. Строгое соблюдение регламента именования хостов.

Формирование сетевых имён (hostname) для всех физических и виртуальных серверов, оборудования и АРМ выполняется в строгом соответствии с Регламентом управления конфигурациями "Правила наименования хостов". Использование явных наименований зон безопасности в именах хостов запрещено [8.4.4 CIS Benchmarks], [8.4.13 ARIN / Microsoft / OneTrust]

7.2.2. Ведение реестра активов в CMDB.

Все изменения в составе оборудования, появление новых ВМ или переназначение IP-адресов должны фиксироваться в базе данных конфигураций (CMDB) с немедленным обновлением A/PTR-записей в DNS [8.4.3 CIS Controls v8], [8.3.6 ГОСТ Р ИСО/МЭК 27001-2021]

7.3. Управление уязвимостями и обновлениями (Patch Management)

7.3.1. Периодический поиск уязвимостей.

Отдел ИБ проводит сканирование инфраструктуры и веб-сервисов на наличие уязвимостей сканером уязвимостей не реже одного раза в месяц, а также после любого существенного обновления систем [8.4.7 б/н от 17.05.2023 (ФСТЭК)], [8.4.8 ГОСТ Р 59711 / 59712], [8.3.4 PCI DSS v4.0]

7.3.2. Сроки установки патчей безопасности.

Обновления для критических уязвимостей (CVSS 8.0 и выше / БДУ ФСТЭК) должны устанавливаться на операционные системы и сервисы в течение 7 календарных дней с момента выхода патча. Для остальных обновлений срок установки составляет не более 30 дней [8.4.7 б/н от 17.05.2023 (ФСТЭК)], [8.4.6 MITRE CWE / CVE / FIRST CVSS], [8.3.4 PCI DSS v4.0]

7.3.3. Безопасная начальная настройка (Hardening).

Все новые серверы Ubuntu 24.04, Windows Server, APM Windows 11 и веб-серверы Nginx перед вводом в эксплуатацию должны настраиваться по согласованным профилям безопасности на базе стандартов CIS Benchmarks [8.4.4 CIS Benchmarks], [8.4.3 CIS Controls v8]

7.4. Порядок реагирования на инциденты ИБ и уведомление Роскомнадзора

7.4.1. Фиксация и расследование инцидентов.

Любые аномалии, подозрения на компрометацию или попытки атак фиксируются Отделом ИБ в Журнале учета инцидентов. Расследование проводится согласно утверждённому регламенту реагирования [8.4.9 ГОСТ Р 59515 / 59516 / NIST SP 800-61], [8.3.6 ГОСТ Р ИСО/МЭК 27001-2021]

7.4.2. Обязательное уведомление Роскомнадзора в течение 24 часов.

При установлении факта утечки или компрометации персональных данных клиентов или сотрудников Отдел ИБ обязан направить первичное уведомление в Роскомнадзор в течение 24 часов, а результаты расследования - в течение 72 часов [8.2.3 ФЗ-266], [8.2.15 б/н (Роскомнадзор)]

8. Управление инцидентами ИБ

8.1. Классификация инцидентов и уровни критичности

8.1.1. Все события и инциденты, выявленные в инфраструктуре ИП «ОдинЗаВсех», подлежат обязательной классификации по уровню критичности для определения сроков и порядка реагирования:
[8.2.9 Приказ ФСТЭК № 21], [8.4.9 ГОСТ Р 59515 / 59516 / NIST SP 800-61]

8.1.2. Уровень 1 (Низкий): Незначительные отклонения, не влияющие на бизнес-процессы (например, блокировка спама, единичная ошибка аутентификации).
8.1.3. Уровень 2 (Средний): Локальная компрометация (например, заражение АРМ пользователя вредоносным ПО без признаков латерального перемещения, попытка подбора пароля).
8.1.4. Уровень 3 (Высокий): Компрометация серверов (srv_web, srv_crm), попытки несанкционированного доступа к базе данных, нарушение доступности критичных сервисов.
8.1.5. Уровень 4 (Критический): Утечка персональных данных (ПДн) клиентов или сотрудников, компрометация платёжных данных (CDE), блокировка инфраструктуры программами-вымогателями, компрометация привилегированных учетных записей Active Directory odin.local.

8.2. Полный жизненный цикл реагирования на инциденты

Процесс реагирования на инциденты ИБ состоит из следующих обязательных этапов:

8.2.1. Обнаружение и фиксация: События выявляются дежурным Отделом ИБ с помощью SIEM/Wazuh, жалоб пользователей или сканеров уязвимостей. Каждый инцидент регистрируется в Журнале учета инцидентов с присвоением уникального номера.

8.2.2. Первичный анализ и классификация: Дежурный ИБ определяет уровень критичности инцидента (согласно п. 8.1).

8.2.3. Локализация (Сдерживание): Принятие немедленных мер по недопущению распространения угрозы (блокировка IP-адресов на fw00_perimeter, изоляция АРМ от сети, блокировка учетной записи в AD odin.local).

8.2.4. Устранение (Эрадикация): Удаление вредоносного кода, закрытие уязвимостей, смена скомпрометированных паролей и ключей (СКЗИ).

8.2.5. Восстановление: Восстановление работоспособности сервисов из доверенных резервных копий (согласно Разделу 9 настоящего Стандарта).

8.2.6. Пост-инцидентный анализ: Составление Отчета об инциденте с указанием первопричины (Root Cause Analysis) и разработка плана корректирующих мероприятий (CAPA), чтобы исключить повторение инцидента.
[8.4.9 ГОСТ Р 59515 / 59516 / NIST SP 800-61]

9. Резервное копирование и восстановление (BCP / DRP)

9.1. Требования к резервному копированию данных

9.1.1. Вся инфраструктура ИП «ОдинЗаВсех» должна быть охвачена процессами резервного копирования. Резервные копии должны создаваться по правилу «3-2-1»: минимум 3 копии данных, на 2 разных типах носителей, 1 из которых хранится географически отдельно или в изолированном облаке.

9.1.2. Что копируется: БД CRM (srv_crm), исходный код таск-менеджера, файловые хранилища, конфигурации fw00_perimeter, контроллер домена odin.local.

9.1.3. Шифрование: Все резервные копии, содержащие ПДн, коммерческую тайну или платежные данные, должны быть зашифрованы (AES-256) как в процессе передачи, так и при хранении.
[8.3.4 PCI DSS v4.0], [8.4.3 CIS Controls v8]

9.2. Целевые показатели восстановления (RTO и RPO)

Для критических систем Предприятия устанавливаются следующие целевые показатели:

9.2.1. RPO (Recovery Point Objective - точка восстановления): Для БД CRM и платёжных модулей - не более 1 часа (инкрементальные бэкапы или репликация). Для остальных систем - не более 24 часов (ежедневный полный бэкап).

9.2.2. RTO (Recovery Time Objective - время восстановления): Для публичных сервисов (srv_web, srv_crm) - не более 4 часов. Для внутренних сервисов - не более 24 часов.

9.3. Тестирование и контроль восстановления

Резервное копирование без проверки восстановления считается нерабочим. Отдел ИБ и IT-отдел обязаны проводить тестовое восстановление данных на изолированный стенд не реже одного раза в квартал. Результаты тестирования оформляются Актом. Логи процессов резервного копирования и статус задач должны направляться в SIEM/Wazuh для контроля.

10. Кадровая безопасность (HR Security)

10.1. Процедуры приема на работу

До предоставления первичного доступа к инфраструктуре Предприятия, HR-служба обязана обеспечить:

10.1.1. Ознакомление кандидата под личную подпись с настоящим Стандартом, Политикой ИБ и Политикой обработки ПДн.

10.1.2. Подписание Соглашения о неразглашении коммерческой тайны (NDA).

10.1.3. Подписание Согласия на обработку персональных данных.

[8.2.4 ФЗ-98], [8.2.2 ФЗ-152]

10.2. Обучение и повышение осведомленности (Security Awareness)

10.2.1. Отдел ИБ обязан проводить вводный инструктаж для всех новых сотрудников.

10.2.2. Впоследствии, все сотрудники (включая удалённых и подрядчиков) обязаны проходить регулярное обучение:

10.2.2.1. Не реже 1 раза в год - курсы по основам ИБ (пароли, MFA, защита ПДн, правила работы с Git).

10.2.2.2. Ежеквартально - имитация фишинговых атак (рассылка тестовых писем). Сотрудники, провалившие тест, направляются на внеплановый инструктаж.

10.3. Процедуры изменения ролей и увольнения (Offboarding)

При переводе сотрудника на другую должность или его увольнении:

10.3.1. HR-служба уведомляет IT и ИБ не позднее чем за 1 рабочий день (при увольнении - в день издания приказа).

10.3.2. IT-отдел немедленно (в течение 1 часа) блокирует учетные записи в AD odin.local, OpenVPN и Git, отзывает токены доступа и сертификаты ЭП (СКЗИ).

10.3.3. Руководитель подразделения принимает материальные носители информации (ноутбуки, токены Рутокен/JaCarta).
[8.4.3 CIS Controls v8]

11. Управление активами (Asset Management)

11.1. Реестр активов и классификация информации

11.1.1. Все информационные активы (серверы, АРМ, ПО, базы данных) подлежат обязательному учету в базе данных конфигураций (CMDB).

11.1.2. Для каждого актива назначается Владелец (Business Owner), несущий ответственность за его использование.

11.1.3. Вся обрабатываемая информация классифицируется по уровням конфиденциальности:
[8.4.3 CIS Controls v8], [8.3.6 ГОСТ Р ИСО/МЭК 27001-2021]

11.1.3.1. Публичная: Сайт srv_web, маркетинговые материалы.

11.1.3.2. Внутренняя: База знаний srv_wiki, внутренние регламенты.

11.1.3.3. Конфиденциальная (Коммерческая тайна): Исходный код, архитектура сети, договоры.

11.1.3.4. Строго конфиденциальная (ПДн и Платежные данные): БД клиентов, данные карт, личные дела сотрудников HR.

11.2. Списание и безопасное уничтожение (Decommissioning)

11.2.1. При списании оборудования (серверов, дисков, АРМ) или выводе из эксплуатации виртуальных машин, все носители информации подлежат гарантированному уничтожению данных. Для HDD и SSD - программное затирание (Overwriting) по стандарту NIST SP 800-88 или физическое разрушение.

11.2.2. Уничтожение ПДн при достижении целей обработки оформляется соответствующим Актом об уничтожении, в соответствии с требованиями ФЗ-152.

[8.2.2 ФЗ-152]

12. Физическая безопасность (Physical Security)

12.1. Контроль доступа в серверные помещения

12.1.1. Доступ в помещение, где размещено сетевое и серверное оборудование (включая fw00_perimeter), разрешен исключительно сотрудникам IT-отдела и Отдела ИБ.

12.1.2. Дверь в серверную должна быть оборудована механическим замком или системой контроля доступа (СКУД).

12.1.3. Ведется Журнал учета посещения серверных помещений.

12.1.4. В серверной должны быть установлены датчики температуры, дыма и системы пожаротушения.

12.2. Безопасность рабочих мест (Clean Desk Policy)

В целях предотвращения утечек информации устанавливается политика «чистого стола»:

12.2.1. Запрещается оставлять документы с ПДн или коммерческой тайной на рабочих столах в нерабочее время. Они должны храниться в запираемых ящиках.

12.2.2. При отходе от АРМ сотрудник обязан заблокировать сессию (Win+L) или включить хранитель экрана с паролем (не более 5 минут бездействия).

12.2.3. Запрещается записывать пароли на стикеры и клеить их на мониторы.

12.3. Защита мобильных устройств и ноутбуков

Ноутбуки, используемые для удаленной работы (подключаемые через OpenVPN), должны иметь обязательное полнодисковое шифрование (BitLocker для Windows, LUKS для Linux). В случае утери или кражи устройства, наличие шифрования предотвратит утечку данных, а доступ к VPN будет немедленно заблокирован.

13. Безопасность третьих лиц (Third-Party Security)

13.1. Взаимодействие с подрядчиками и вендорами

Любые внешние подрядчики (аутсорсинг, ремонт оборудования, разработка на заказ), которым требуется доступ к инфраструктуре ИП «ОдинЗаВсех», обязаны:

13.1.1. Подписать Соглашение о неразглашении (NDA) и ознакомиться с настоящим Стандартом.

13.1.2. Предоставлять доступ подрядчикам только через бастион-хост (Bastion) или выделенный гостевой VLAN с обязательным протоколированием всех действий (сессий SSH/RDP).

13.1.3. Время удаленного доступа подрядчиков должно быть ограничено периодом выполнения работ (Just-In-Time access). По завершении работ доступ отзывается в течение 1 часа.

13.2. Управление цепочкой поставок ПО

Приобретение или использование стороннего программного обеспечения, библиотек и фреймворков должно сопровождаться проверкой на отсутствие известных уязвимостей

(сверка с БДУ ФСТЭК и CVE) и легальностью их использования (лицензии). Использование пиратского ПО в инфраструктуре Предприятия строго запрещено.
[8.4.1 ГОСТ Р 56939-2024], [8.4.10 БДУ ФСТЭК]

14. Ссылки на НПА и стандарты

14.1. Обоснование применимости нормативной базы для ИП«ОдинЗаВсех»

14.1.1. Обязательное применение по законодательству РФ

14.1.1.1. ФЗ-152, ПП-1119, Приказ ФСТЭК № 21, Приказ ФСБ № 378, Приказ ФАПСИ № 152, Приказы РКН (№ 14, 178, 996), ФЗ-266:
Обоснование: Компания обрабатывает персональные данные физических лиц в нескольких системах (ПДн сотрудников в HR, ПДн клиентов в CRM srv_crm, на сайте srv_web, личных кабинетах и файловых серверах). Компания обязана обеспечить уровни защищенности ИСПДн, уведомить Роскомнадзор, оперативно (в течение 24 часов) сообщать об утечках и вести учет криптографических ключей (OpenVPN, HTTPS-сертификаты).

14.1.1.2. ФЗ-149, Указ Президента № 188:
Обоснование: Базовый закон об информации и конфиденциальности. Определяет обязанности операторов информсистем и порядок защиты конфиденциальной информации.

14.1.1.3. ФЗ-63 «Об электронной подписи»:
Обоснование: Компания использует ЭП для кадрового и финансово-бухгалтерского документооборота, взаимодействия с налоговыми органами и контрагентами.

14.1.1.4. ФЗ-98 «О коммерческой тайне»:
Обоснование: Компания разрабатывает проприетарное ПО, хранит исходный код на файловом сервере и работает с коммерческими профайлами клиентов. Требуется защита режима коммерческой тайны.

14.1.2. Обязательное применение по распоряжению руководства

14.1.2.1. OWASP Top 10:
Обоснование: Прямое требование задачи. Применяется к веб-сервисам srv_crm (CRM-система) и srv_web (публичный сайт, портал самообслуживания) для защиты от веб-атак (инъекции, XSS, ошибки аутентификации).

14.1.2.2. NIST SP 800-41 Rev. 1 (+ NIST SP 800-207, CIS C12):
Обоснование: Прямое требование задачи. Применяется к единственному периметровому межсетевому экрану fw00_perimeter для правила фильтрации, сегментации (DMZ, Users, Servers, Infra) и контроля трафика.

14.1.2.3. PCI DSS v4.0:
Обоснование: Прямое требование задачи. Сервисы srv_web и srv_crm обрабатывают онлайн-платежи клиентов за подписки SaaS и проекты.

14.1.2.4. ГОСТ Р 57580.1-2017:
Обоснование: Задано условиями задачи как отраслевой ориентир для защиты финансовых транзакций и контура обработки платежей на srv_web и srv_crm.

14.1.2.5. ГОСТ Р ИСО/МЭК 27001-2021 / 27002-2021:
Обоснование: Прямое требование задачи. Выступает верхнеуровневой основой (СУИБ) для корпоративного стандарта и охватывает все 4 сегмента сети.

14.1.3. Не применимые в компании

14.1.3.1. Законодательство по КИИ (ФЗ-187, ПП-127, ПП-162, ПП-452, Приказы ФСТЭК № 235/239/77/282, Приказы ФСБ № 196/282/367/366):
Обоснование: ООО «ОдинЗаВсех» - коммерческая IT-студия. Компания не является субъектом КИИ (не относится к сферам энергетики, транспорта, здравоохранения, банков, науки, оборонной промышленности и т.д.).
14.1.3.2. Требования к ГИС (ПП-676, Приказ ФСТЭК № 17, Приказ ФСБ № 524):
Обоснование: Компания эксплуатирует собственные коммерческие ИС и SaaS-платформу. У неё нет статуса Государственной информационной системы (ГИС).

14.1.3.3. Государственная тайна (ФЗ-5485-1, Указ № 1203, Инструкция № 3-1):
Обоснование: Компания не работает со сведениями, составляющими государственную тайну.
14.1.3.4. Законодательство о госзакупках и импортозамещении для госсектора (ФЗ-44, ПП-1236, Указы № 166, 250):
Обоснование: «ОдинЗаВсех» - частная коммерческая компания. Указы № 250/166 и ПП-1236 распространяются на госорганы, ГУПы, госкорпорации и значимые объекты КИИ.

14.1.3.5. Банковское регулирование ЦБ РФ (Положения 683-П/802-П, 684-П/757-П, 719-П/821-П, 747-П, 716-П, СТО БР):
Обоснование: Компания не является банком, НФО или оператором платежной системы. (Требования к платежам закрываются через PCI DSS и ГОСТ Р 57580.1 в рамках договора с эквайером).

14.1.3.6. Промышленная безопасность и АСУ ТП (Приказ ФСТЭК № 31, ГОСТ Р МЭК 62443, NIST SP 800-82):
Обоснование: В инфраструктуре отсутствуют технологические процессы, датчики, контроллеры (OT/ICS/SCADA).

14.1.3.7. Законодательство об операторах связи (ФЗ-126) и лицензирование (ФЗ-99, ПП-313, ПП-79):
Обоснование: Компания не оказывает услуги связи третьим лицам и не предоставляет коммерческие услуги по лицензируемой защите информации / разработке СКЗИ на заказ.

14.1.4. Желательное применение (Лучшие практики и методологии)

14.1.4.1. ГОСТ Р 56939-2024, NIST SP 800-218 (SSDF), OWASP SAMM v2.0:
Обоснование: Критически важны для IT-студии с собственной разработкой таск-менеджера. Регламентируют DevSecOps, статический анализ кода (SAST), фаззинг и безопасность сборочных пайплайнов.

14.1.4.2. CIS Controls v8, CIS Benchmarks:

Обоснование: Идеальны для подготовки технических регламентов настройки (hardening) серверных ОС (Linux Ubuntu 24.04), рабочих станций (Windows 11), контроллера домена (Windows Server) и веб-серверов Nginx.

14.1.4.3. MITRE ATT&CK, D3FEND, CWE, CVE, CVSS, БДУ ФСТЭК:
Обоснование: Необходимы отделу ИБ для разбора результатов проведенного пентеста, классификации выявленных уязвимостей, моделирования угроз и настройки правил мониторинга.

14.1.4.4. Примеры и шаблоны (ARIN, Microsoft, OneTrust, Южная Австралия, Тасмания, Cisco):
Обоснование: Служат методической и структурной основой при написании самого корпоративного стандарта компании (формулировки целей, распределение ролей между IT, ИБ, Dev и менеджментом).

14.2. НПА и стандарты обязательные к применению по законодательству РФ

В эту группу входят федеральные законы, указы и подзаконные акты, соблюдение которых является требованием законодательства Российской Федерации для ИП «ОдинЗаВсех» как оператора персональных данных и юридического лица.

№ п/п	Номер закона	Название	Описание	Примечание
1.	**ФЗ-149**	**Об информации, информационных технологиях и о защите информации**	Базовые требования к защите информации, ограничению доступа и эксплуатации информационных систем.	Все сегменты сети, корпоративные сервисы, SaaS-платформа.
2.	**ФЗ-152**	**О персональных данных**	Требования к законности обработки, хранению, локализации и защите ПДн клиентов и сотрудников.	ИСПДн: srv_crm (CRM), srv_web (сайт/портал), Файловый сервер HR/менеджеров, БД CRM.
3.	**ФЗ-266**	**О внесении изменений в ФЗ «О персональных данных»**	Обязательное уведомление Роскомнадзора об инцидентах и утечках ПДн в течение 24 часов.	Отдел ИБ, ИСПДн (srv_crm, srv_web, Файловый сервер HR).
4.	**ФЗ-98**	**О коммерческой тайне**	Порядок защиты сведений, составляющих коммерческую тайну (исходный код, проекты клиентов).	Файловый сервер (проектная документация, исходный код), АРМ разработчиков и менеджеров (10.10.4.0/25).
5.	**ФЗ-63**	**Об электронной подписи**	Правила применения и юридическая сила электронных подписей при документообороте.	Рабочие станции финансово-бухгалтерского отдела, HR и руководства.
6.	**Указ № 188**	**Об утверждении Перечня сведений конфиденциального характера**	Официальный перечень категорий конфиденциальной информации (ПДн, коммерческая тайна).	Все сегменты сети компании (10.10.1.0/27, 10.10.2.0/26, 10.10.4.0/25, 10.10.5.0/28).
7.	**ПП № 1119**	**Требования к защите персональных данных при их обработке в ИСПДн**	Классификация ИСПДн по уровням защищенности (УЗ 1–4) и базовые требования к их защите.	Все ИСПДн компании (srv_crm, srv_web, Файловый сервер HR/менеджеров).
8.	**ПП № 1272**	**Порядок осуществления госконтроля за обработкой**	Правила проведения проверок деятельности оператора ПДн	Процессы обработки ПДн, отдел HR, менеджеры,

№ п/п	Номер закона	Название	Описание	Примечание
		ПДн	со стороны Роскомнадзора.	отдел ИБ.
9.	**Приказ ФСТЭК № 21**	**Состав и содержание мер по обеспечению безопасности ПДн**	Конкретный перечень организационных и технических мер защиты ПДн для уровней УЗ-1–УЗ-4.	ИСПДн: srv_crm, srv_web, БД CRM, Файловый сервер HR, АРМ пользователей (10.10.4.0/25).
10.	**б/н от 05.02.2021**	**Методика оценки угроз безопасности информации ФСТЭК**	Порядок идентификации и моделирования угроз безопасности информации в ИСПДн.	Отдел ИБ, процессы проектирования и защиты всех информационных систем компании.
11.	**Приказ ФСБ № 378**	**Состав и содержание мер по обеспечению безопасности ПДн при использовании СКЗИ**	Требования к криптографической защите каналов и данных при обработке ПДн.	VPN-сервер OpenVPN (10.10.1.0/27), HTTPS-трафик srv_web/srv_crm, зашифрованные каналы связи.
12.	**Приказ ФАПСИ № 152**	**Инструкция по организации и обеспечению безопасности хранения, обработки и передачи информации с СКЗИ**	Поэкземплярный учет, хранение, поэкземплярный контроль и правила работы с ключевыми документами и СКЗИ.	АРМ пользователей с ЭП, VPN-сервер, сертифицированные СКЗИ, отдел ИБ / IT-отдел.
13.	**№ 149/7/2/6-432**	**Методические рекомендации ФСБ по определению класса СКЗИ**	Порядок выбора требуемого класса криптографических средств (КС1–КС3) для защиты ПДн.	Отдел ИБ, проектирование защиты VPN (OpenVPN) и веб-сервисов (srv_web, srv_crm).
14.	**Приказы РКН № 14, 178, 996**	**Требования к уведомлениям, обезличиванию и согласиям на распространение ПДн**	Формы подачи уведомлений в РКН, правила получения согласий и методики обезличивания ПДн.	Отдел HR, Менеджеры, веб-сервисы srv_web и srv_crm (формы сбора данных).
15.	**б/н (Роскомнадзор)**	**Методические рекомендации по уведомлению об инцидентах с ПДн**	Порядок и форматы подачи первичных и итоговых уведомлений в РКН при утечках ПДн.	Отдел ИБ, регламенты реагирования на инциденты ИБ.

14.3. НПА и стандарты обязательные к применению по по распоряжению руководства

В эту группу входят международные и национальные стандарты, фреймворки и спецификации, выполнение которых закреплено техническим заданием и решением руководства компании для построения эффективного стандарта ИБ.

№ п/п	Номер закона	Название	Описание	Примечание
1.	**OWASP Top 10 (2021) / API Top 10 (2023)**	**OWASP Web Application & API Security Risks**	Стандарт защиты от наиболее критических уязвимостей веб-приложений и API (инъекции, XSS, SSRF, ошибки доступа).	Веб-сервис srv_crm (CRM-система), веб-сервис srv_web (сайт, личный кабинет), портал самообслуживания.
2.	**NIST SP 800-41 Rev. 1**	**Guidelines on Firewalls and Firewall Policy**	Рекомендации по проектированию, настройке политик фильтрации, аудиту и управлению межсетевыми экранами.	Межсетевой экран fw00_perimeter, правила фильтрации между сегментами (DMZ, Users, Servers, Infra).
3.	**NIST SP 800-207**	**Zero Trust Architecture**	Концепция «нулевого доверия» для построения микросегментации и строгой проверки всех сетевых соединений.	Межсетевой экран fw00_perimeter, сетевые интерфейсы всех 4 сегментов сети.
4.	**PCI DSS v4.0**	**Payment Card Industry Data Security Standard**	Стандарт безопасности данных индустрии платежных карт (шифрование, сегментация, контроль доступа, логирование).	Веб-сервис srv_web, веб-сервис srv_crm (модули приема онлайн-платежей за подписки), БД CRM.
5.	**ГОСТ Р 57580.1-2017**	**Безопасность финансовых (банковских) операций. Защита информации финансовых организаций**	Защита финансовых транзакций, платёжных контуров, контроль целостности и конфиденциальности платежей.	Контур обработки платежей на srv_web и srv_crm, финансово-бухгалтерский отдел, Файловый сервер финотдела.
6.	**ГОСТ Р ИСО/МЭК 27001-2021**	**Системы менеджмента информационной безопасности. Требования**	Требования к построению, внедрению, мониторингу и непрерывному улучшению СУИБ/СМИБ в компании.	Все сегменты сети (10.10.1.0/27, 10.10.2.0/26, 10.10.4.0/25, 10.10.5.0/28), все отделы и роли компании.

14.4. НПА и стандарты желательные к применению (лучшие практики и методологии)

В эту группу входят открытые стандарты, технические руководства (benchmarks) и методологии, которые рекомендуется использовать отделу ИБ, IT-отделу и отделу разработки для устранения замечаний пентеста, безопасной настройки систем и организации процессов.

№ п/п	Номер закона	Название	Описание	Примечание
1.	**ГОСТ Р 56939-2024 / ГОСТ Р 58412-2019**	**Защита информации. Разработка безопасного программного обеспечения**	Требования к интеграции проверок ИБ в цикл разработки ПО (DevSecOps), статический/динамический анализ кода.	Отдел разработки, сборочные пайплайны, исходный код таск-менеджера, тестовые среды.
2.	**NIST SP 800-218 (SSDF) / OWASP SAMM v2.0**	**Secure Software Development Framework / Software Assurance Maturity Model**	Фреймворки и модели зрелости безопасной разработки программного обеспечения.	Отдел разработки, управление уязвимостями в коде, процессы ревью кода (Code Review).
3.	**CIS Controls v8**	**CIS Critical Security Controls**	18 приоритизированных базовых контролей ИБ (инвентаризация, защита АРМ, логирование, контроль доступов).	Вся ИТ-инфраструктура, IT-отдел, Отдел ИБ.
4.	**CIS Benchmarks**	**CIS Security Configuration Benchmarks**	Практические руководства по безопасной настройке (hardening) ОС, веб-серверов и СУБД.	Серверы Ubuntu 24.04 (10.10.2.0/26, 10.10.5.0/28), АРМ Windows 11 (10.10.4.0/25), Windows Server, Nginx.
5.	**MITRE ATT&CK / D3FEND**	**Adversarial Tactics, Techniques & Defensive Countermeasures**	Базы знаний тактик/техник злоумышленников и графы оборонительных технических мер противодействия.	Отдел ИБ, анализ результатов пентеста, настройка правил мониторинга и обнаружения атак.
6.	**MITRE CWE / CVE / FIRST CVSS**	**Weakness Enumeration / Vulnerabilities / Scoring System**	Справочники видов ошибок (CWE), конкретных уязвимостей (CVE) и система оценки их критичности (CVSS).	Процесс управления уязвимостями, Отдел ИБ, Отдел разработки (приоритизация патчей).
7.	**б/н от**	**Руководство по**	Порядок организации	Все серверы, веб-сервисы,

№ п/п	Номер закона	Название	Описание	Примечание
	17.05.2023 (ФСТЭК)	**организации процесса управления уязвимостями**	непрерывного процесса инвентаризации, сканирования и устранения уязвимостей.	АРМ сотрудников, IT-отдел.
8.	**ГОСТ Р 59711 / 59712**	**Защита информации. Управление уязвимостями**	Национальные стандарты по правилам определения, квалификации и мониторинга уязвимостей.	IT-отдел, Отдел ИБ, процессы патч-менеджмента.
9.	**ГОСТ Р 59515 / 59516 / NIST SP 800-61**	**Управление компьютерными инцидентами / Incident Handling Guide**	Порядок организации процессов реагирования, фиксации, анализа и ликвидации последствий инцидентов ИБ.	Отдел ИБ, регламенты реагирования на киберинциденты.
10.	**БДУ ФСТЭК**	**Банк данных угроз безопасности информации**	База данных уязвимостей и угроз ПО для проведения анализа и проверки используемых компонентов.	Отдел ИБ, Отдел разработки (проверка сторонних библиотек и компонентов).
11.	**ПП № 325**	**Положение о реестре российского ПО**	Критерии и требования к программному обеспечению для включения в Единый реестр отечественного ПО.	Продукты собственной разработки (SaaS-платформа таск-менеджера).
12.	**NIST CSF v2.0**	**NIST Cybersecurity Framework**	Верхнеуровневая система управления киберрисками по функциям: Govern, Identify, Protect, Detect, Respond, Recover.	Руководство компании, Отдел ИБ (оценка зрелости ИБ).
13.	**ARIN / Microsoft / OneTrust (Whitepapers)**	**Public Security Policies & Whitepapers**	Публичные корпоративные стандарты и отчеты о безопасности инфраструктур ведущих компаний.	Отдел ИБ (использование как бенчмарки и образцы формулировок политик).
14.	**South Australia Guidance / TAS Guide / Cisco Framework**	**Cyber Security Policy & Implementation Guidance**	Методические руководства по написанию, структурированию и внедрению корпоративных политик ИБ.	Отдел ИБ, Руководство компании (при формировании структуры корпоративного стандарта).
15.	**ГОСТ Р ИСО/МЭК 27002-2021**	**Свод практик по управлению информационной безопасностью**	Детальный каталог практических организационных, кадровых, физических и технических мер ИБ.	Отдел ИБ, IT-отдел (детализация требований к защите АРМ, серверов и сетей).